



Asset ID
A1
A2
A3
A4
A5
A6
A7
A8

Assets Lits

Asset	Importance
Patient Medical Data	Critical
User Credentials	Critical
IoT Device Firmware	High
Cloud Server	Critical
Patient Database	Critical
Doctor Portal	High
API Gateway	High
Network Communication	High

Trust Boundaries

Trust Boundary
TB1
TB2
TB3
TB4



Description
Internet between Mobile App and Cloud
IoT Device to Mobile App
Doctor accessing Cloud Portal
Database Access



Threat ID	STRIDE
T1	Spoofing
T2	Spoofing
T3	Tampering
T4	Tampering
T5	Repudiation
T6	Repudiation
T7	Information Disclosure
T8	Information Disclosure
T9	Denial of Service
T10	Denial of Service
T11	Elevation of Privilege
T12	Elevation of Privilege

STRIDE Analysis

Threat	Asset
Fake doctor login	Doctor Portal
Fake IoT device	Cloud Server
Modify patient records	Database
Firmware modification	IoT Device
Doctor denies updating record	Logs
Patient denies alert	Notification System
Database leak	Patient Data
API token theft	API Gateway
DDoS attack	Cloud Server
API Flooding	API Gateway
Admin privilege escalation	Server
SQL Injection	Database

Impact
Unauthorized access
False patient data
Wrong treatment
Device malfunction
Audit failure
Legal issues
Privacy breach
Account compromise
Monitoring unavailable
Service outage
Full compromise
Complete data loss

DREAD Risk Assessment

Threat	D	R	E
Fake Login	8	7	8
SQL Injection	10	9	8
Data Leak	10	8	8
Firmware Attack	8	6	6
DDoS	9	8	7



A	D	Score	Risk
9	8	40	High
9	10	46	Critical
10	9	45	Critical
8	8	36	High
9	8	41	High



Threat
Fake Login
SQL Injection
Data Leakage
API Attack
Device Spoofing
Firmware Attack
DDoS
Privilege Escalation
Repudiation
Credential Theft

Security Controls

Mitigation
Multi-Factor Authentication (MFA)
Prepared Statements and Input Validation
AES-256 Encryption at Rest
OAuth 2.0 + JWT
Device Certificates
Secure Boot and Signed Firmware
Web Application Firewall (WAF) and Rate Limiting
Role-Based Access Control (RBAC)
Centralized Audit Logging
Strong Password Policy

Prioritized Mitigations

Priority	Control
1	MFA
2	Encryption
3	Secure APIs
4	RBAC
5	Signed Firmware
6	WAF
7	Continuous Monitoring
8	Backup and Recovery
9	Vulnerability Scanning
10	Incident Response Plan

tions

Reason
Prevent unauthorized access
Protect sensitive patient data
Prevent API abuse
Limit access permissions
Prevent malicious firmware installation
Mitigate web attacks
Detect attacks early
Recover from ransomware
Identify weaknesses
Reduce recovery time

Risk Mat

Threat	Likelihood
SQL Injection	High
Data Leak	High
Fake Login	High
DDoS	Medium
Firmware Attack	Medium
Insider Threat	Medium
Device Theft	Medium

rix

Impact	Risk
High	Critical
High	Critical
High	High
High	High
High	High
Medium	Medium
Medium	Medium

MITF

Threat
Phishing
Credential Theft
SQL Injection
Privilege Escalation
Data Exfiltration
DDoS

RE ATT&CK Mapping

MITRE ATT&CK Technique
T1566 – Phishing
T1003 – OS Credential Dumping
T1190 – Exploit Public-Facing Application
T1068 – Exploitation for Privilege Escalation
T1041 – Exfiltration Over C2 Channel
T1498 – Network Denial of Service